



Gobierno de
México

Plataforma Única de Identidad

Guía de herramientas para pruebas de ciberseguridad

Versión 1.0 | 16/04/2026

Índice

1. Objetivo General	3
2. Alcance del Manual	3
3. Definiciones	3
4. Comunicación Informativa	4
5. Static Application Security Testing (SAST)	4
6. Software Composition Analysis (SCA)	5
7. Dynamic Application Security Testing (DAST)	6
8. Envío de reporte de evidencia y pruebas	7
Requisitos de Seguridad – Pruebas SCA para la PUI	8

1. Objetivo General

El presente documento tiene como objetivo **presentar diversas herramientas de revisión de seguridad aplicables al desarrollo de software, con especial énfasis en su uso dentro del ciclo de desarrollo de la API de la Plataforma Única de Identidad, con el fin de cumplir con los requisitos de ciberseguridad para el uso de dicha plataforma**. Se busca proporcionar una visión general de las opciones disponibles en el mercado, facilitando la identificación de capacidades relevantes para fortalecer la seguridad, calidad y confiabilidad de los servicios expuestos.

Este documento es de carácter informativo y no pretende guiar ni influir en la selección de herramientas específicas. Cada organización deberá analizar, evaluar e implementar aquellas soluciones que mejor se alineen con sus necesidades, arquitectura tecnológica y contexto operativo.

2. Alcance del Manual

Las herramientas mencionadas en el presente documento tienen como finalidad la ejecución de las pruebas de seguridad obligatorias, así como la generación de los reportes establecidos en el numeral 10 “Requisitos de ciberseguridad para el uso de la Plataforma Única de Identidad por parte de instituciones diversas”, en el apartado “Reportes de seguridad”, comprendido en las páginas 58 a 60 del [Manual Técnico de la Solución Tecnológica para Instituciones Diversas](#), publicado el 23 de enero de 2026 en el Diario Oficial de la Federación.

Las pruebas a realizar son las siguientes:

- Static Application Security Testing (SAST)
- Software Composition Analysis (SCA)
- Dynamic Application Security Testing (DAST)

3. Definiciones

Término / Sigla	Descripción
Static Application Security Testing	Es un método de seguridad que analiza el código fuente, binarios o bytecodes de una aplicación sin ejecutarla para

Término / Sigla	Descripción
(SAST)	detectar vulnerabilidades en etapas tempranas. Funciona como una inspección de "caja blanca" que ayuda a los desarrolladores a corregir fallos de seguridad antes de la implementación.
Software Composition Analysis (SCA)	Es un proceso de seguridad que permite identificar y evaluar las dependencias de terceros y componentes de código abierto utilizados en una aplicación. En el contexto de la Plataforma Única de Identidad (PUI) , se utiliza para verificar que las librerías integradas en sus APIs no presenten vulnerabilidades conocidas, riesgos de licenciamiento ni desactualizaciones que comprometan la seguridad del sistema.
Dynamic Application Security Testing (DAST9)	Es un método de seguridad que identifica vulnerabilidades en aplicaciones web y API en tiempo de ejecución, simulando ataques externos sin acceder al código fuente. Actúa como un "hacker ético" (caja negra) para encontrar fallos críticos como inyección SQL, Cross-Site Scripting (XSS) y errores de configuración.

4. Comunicación Informativa

Las recomendaciones sobre herramientas de escaneo SAST, SCA y DAST son actuales y orientativas. **Se presentan de manera enunciativa y no limitativa**, ya que no se han evaluado todas las opciones disponibles. Es necesario realizar una evaluación interna y verificar cómo cada herramienta se adapta al flujo de desarrollo, tecnología utilizada, alcance y a los procesos de trabajo específicos de la organización, considerando sus capacidades y limitaciones. El uso de herramientas open source frente a herramientas licenciadas conlleva ciertos riesgos que deben evaluarse cuidadosamente. Las herramientas open source dependen de la comunidad para soporte, actualizaciones y parches de seguridad, lo que puede generar vulnerabilidades o retrasos en la resolución de problemas.

5. Static Application Security Testing (SAST)

Es una técnica de seguridad de aplicaciones que analiza el código fuente, bytecode o binarios sin necesidad de ejecutar la aplicación, con el objetivo de identificar vulnerabilidades desde etapas tempranas del desarrollo. Se considera una prueba de tipo “caja blanca”, ya que examina la aplicación “desde dentro”, permitiendo detectar problemas como:

- Inyecciones SQL
- Cross-Site Scripting (XSS)
- Errores de manejo de memoria
- Fallos de lógica de seguridad

Herramientas con Licenciamiento

- Checkmarx (One/SAST).
 - Reconocido como Líder en Gartner 2025
 - Alta cobertura de lenguajes
 - Buen balance entre precisión y automatización
- Fortify (Static Code Analyzer)
 - Líder por más de 10 años consecutivos en Gartner
 - Análisis profundo y robusto para entornos empresariales
 - Fuerte enfoque en compliance.
- Veracode.
 - SAST en modelo SaaS
 - Gestión de riesgo integral
 - Remediación asistida con IA

Herramientas Open Source

- Semgrep
 - Reconocido en Gartner Magic Quadrant 2025
 - SAST moderno basado en reglas
 - Open source (Community Edition)
 - Muy rápido y fácil de integrar
 - Reduce falsos positivos con análisis contextual

6. Software Composition Analysis (SCA)

El Análisis de Composición de Software (Software Composition Analysis – SCA) es un proceso automatizado que identifica y analiza los componentes de terceros y open source dentro de una aplicación, con el objetivo de detectar vulnerabilidades conocidas, problemas de licenciamiento y riesgos de seguridad en la cadena de suministro de software. Las herramientas SCA ayudan a asegurar que los componentes de la aplicación sean seguros y cumplan con las políticas de seguridad y cumplimiento antes de su despliegue.

Herramientas con Licenciamiento

- Checkmarx One.
 - Plataforma Unificada que incluye capacidades SCA, SAST y DAST
 - Alta cobertura de lenguajes
 - Buen balance entre precisión y automatización
- Mend.io (antes WhiteSource)
 - Solución empresarial líder en análisis de composición de software
 - Detección de vulnerabilidades, gestión de licencias.
 - Políticas de Seguridad de Código Abierto

Herramientas Open Source

- Snyk
 - Integración sencilla a Desarrollo e Integración continua.
 - Priorización y corrección de Vulnerabilidades.
- Owasp Dependency-Check
 - Realiza la comparación de bases públicas de CVE y NVD
 - Ampliamente adoptada como punto de partida.

7. Dynamic Application Security Testing (DAST)

Son una metodología de pruebas de seguridad que evalúa una aplicación en ejecución desde fuera hacia dentro, sin acceso al código fuente, simulando ataques reales que un atacante podría realizar para identificar vulnerabilidades explotables en tiempo de ejecución. Estas pruebas interactúan con la aplicación en su estado activo, enviando solicitudes maliciosas (como inyecciones SQL, XSS, fallos de autenticación, etc.) para

observar cómo responde la aplicación y detectar brechas o comportamientos inseguros en el entorno de ejecución.

Herramientas con Licenciamiento

- Burp Suite (PortSwigger)
 - Muy potente para pruebas manuales y personalizadas, con proxy de interceptación y extensiones para escenarios complejos.
 - Gran capacidad de personalización y control detallado del escaneo y explotación de fallos.
 - Escaneo interactivo y herramientas auxiliares (mapa de sitio, fuzzer, autenticación, plugins) que lo hacen ideal para pentesting avanzado.
- Rapid7 Insight App Sec
 - Automatización con contexto de riesgo: escanea webs, apps y APIs de forma automatizada y prioriza hallazgos para reducir riesgos de seguridad.
 - Integración con procesos DevSecOps: facilita reportes y colabora con herramientas de ticketing como Jira, con detalles que ayudan a los desarrolladores a corregir errores rápidamente.
 - Amplia cobertura de ataques: incluye más de 95 tipos de ataques y funciones como Attack Replay para validar vulnerabilidades contra parches.

Herramientas Open Source

- OWASP Zed Attack Proxy (ZAP)
 - Totalmente gratuito y sin licencias atadas: ideal para equipos con presupuesto limitado o para pruebas exploratorias.
 - Comunidad activa y extensible: muchos complementos que amplían sus capacidades.
 - Integración en CI/CD: puede automatizarse en pipelines modernos de desarrollo.

8. Envío de reportes de evidencia y pruebas

De cada una de las pruebas de seguridad realizadas se deberá generar un reporte ejecutivo de hallazgos, así como las evidencias que respalden los resultados obtenidos.

A continuación, se presenta por cada una de las pruebas la información mínima que se espera obtener en cada tipo de prueba, en el contexto del desarrollo de APIs de la Plataforma Única de Identidad (PUI). Esta información tiene como finalidad orientar sobre el nivel de detalle, trazabilidad y calidad de los entregables que se requieren.

Pruebas SAST para la PUI

- Se deberá ejecutar análisis estático de seguridad sobre el código fuente de los servicios y APIs que conforman la PUI, previo a su despliegue.
- El análisis deberá identificar vulnerabilidades relevantes para servicios de identidad, incluyendo inyección SQL (SQLi), cross-site scripting (XSS), ejecución remota de código (RCE) y fallas en el manejo de datos sensibles.
- No se considerarán válidas como evidencia las pruebas unitarias o funcionales que no evalúen riesgos de seguridad en el código.
- El reporte deberá especificar claramente el componente evaluado de la PUI, así como la versión, rama o commit correspondiente.
- Se deberá documentar la configuración del análisis, incluyendo reglas aplicadas y criterios de evaluación de seguridad.
- Los resultados deberán incluir el detalle de vulnerabilidades detectadas o su justificación formal en caso de ausencia.
- Se deberá garantizar la trazabilidad entre el análisis realizado y la versión del código desplegado en los entornos de la PUI.

Pruebas SCA para la PUI

- Se deberá realizar análisis de composición de software sobre todas las dependencias utilizadas por los servicios y APIs de la PUI.
- El análisis deberá identificar vulnerabilidades conocidas, riesgos de licenciamiento y uso de componentes desactualizados que puedan afectar la seguridad de la plataforma.
- No se aceptarán como evidencia resultados en formato de imagen o capturas de pantalla.
- El reporte deberá generarse en un formato estructurado que permita su validación, auditoría y reproducción.
- Se deberá incluir la identificación del servicio o API de la PUI evaluado, así como el archivo de dependencias correspondiente.
- Se deberá garantizar la trazabilidad del análisis, incluyendo el entorno de ejecución y la versión evaluada.
- Los resultados deberán permitir verificar la integridad de la cadena de suministro de software dentro de la PUI.

Pruebas DAST para la PUI

- Se deberá ejecutar análisis dinámico de seguridad sobre los servicios en ejecución de la PUI, incluyendo todos los endpoints expuestos por sus APIs.
- El análisis deberá contemplar escenarios propios de servicios de identidad, como autenticación, autorización, gestión de sesiones y protección de datos sensibles.
- Se deberán evaluar vulnerabilidades alineadas al OWASP Top 10, así como pruebas de inyección, manipulación de parámetros y validación de entradas.
- No se considerarán válidas como evidencia pruebas limitadas a la verificación de códigos de respuesta HTTP o validaciones básicas de acceso.
- El análisis deberá cubrir la totalidad de endpoints relevantes, incluyendo aquellos protegidos mediante mecanismos de autenticación.
- El reporte deberá documentar los mecanismos de autenticación utilizados durante las pruebas.
- Se deberán detallar los endpoints evaluados, los payloads utilizados y las respuestas completas del sistema.
- Los resultados deberán ser claros, verificables y permitir identificar riesgos que afecten la seguridad de la PUI en operación.

Una vez concluidas las pruebas, se deberán remitir los reportes de hallazgos y las evidencias que los respalden a los siguientes dos correos electrónicos: soportetecnicopui@transformaciondigital.gob.mx y gestion_pui@segob.gob.mx.

Todos los reportes de seguridad deberán ser entregados en formato PDF, garantizando su integridad, legibilidad y portabilidad para efectos de revisión, auditoría y resguardo.

Dichos entregables serán revisados por el área especializada correspondiente, la cual notificará a la institución el resultado de la validación vía correo electrónico. En caso de que la información no cumpla con los requisitos mínimos establecidos, los reportes serán devueltos a la institución emisora para su ajuste y reenvío.

Cuando las pruebas cumplan satisfactoriamente con lo solicitado, se notificará a la institución por correo para dar inicio al proceso de conexión y al arranque formal de operación dentro de la Plataforma Única de Identidad (PUI).